TP Complet — Analyse et Emulation de Firmware Wi-Fi

Jour 2 — Version Etudiants

Modules : TP1 Analyse Statique | TP2 Reverse Engineering | TP3 Emulation
TP4 Analyse Dynamique | TP5 Patching Defensif

Anne-Laure JEAN LOUIS PRS CS 26.3

Cadre legal et ethique

Travailler uniquement sur des firmwares publics ou dans un cadre autorise. VM isolee obligatoire. Ce TP est a finalite pedagogique et defensive uniquement.

TP 1 — Analyse Statique avec Binwalk

Objectifs

- Extraire le firmware d'un routeur Wi-Fi
- Identifier le systeme de fichiers et les composants
- Rechercher des informations sensibles et des vulnerabilites

Etapes

1. Installation des outils

```
sudo apt update && sudo apt install binwalk
```

2. Telechargement d'une image firmware

Telecharger une image firmware publique (ex : routeur Ubiquiti, D-Link, TP-Link).

Image téléchargée DIR-605L_REVB1_FW_v2.02b02.bin, firmware public D-Link. Ce firmware ne dispose pas de partie web.

3. Analyse du firmware

```
binwalk firmware.bin
```

```
┌──(kali㉿kali)-[~/Downloads]
└─$ binwalk DIR-605L_REVB1_FW_v2.02b02.bin

DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
11280         0x2C10          LZMA compressed data, properties: 0x5D, dictionary size: 83
88608 bytes, uncompressed size: 2420736 bytes
631842        0x9A422         Squashfs filesystem, big endian, version 2.0, size: 75676 b
ytes, 7 inodes, blocksize: 65536 bytes, created: 2013-07-12 00:51:09
709684        0xAD434         Squashfs filesystem, big endian, version 2.0, size: 2387328
 bytes, 511 inodes, blocksize: 65536 bytes, created: 2013-07-12 00:51:36
```

0xA4D434 taille de 2387328 plus importants, contient probablement plus de fichiers et possiblement des fichiers de configuration.

4. Extraction recursive du firmware

```
cd ~/IoT/formation-Jour2
rm -rf _firmware.bin.extracted
binwalk -Me firmware.bin
```

```
Scan Time:     2026-04-01 04:38:55
Target File:   /home/kali/Downloads/_DIR-605L_REVB1_FW_v2.02b02.bin.extracted/2C10
MD5 Checksum:  15d07fe18c71610a5b6c4feda66b5a73
Signatures:    436

DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
```

Dossier bin extracted crée.

Options utilisees :

- -M : mode recursif (analyse tout ce qui est compresse dans le firmware)
- -e : extraction automatique

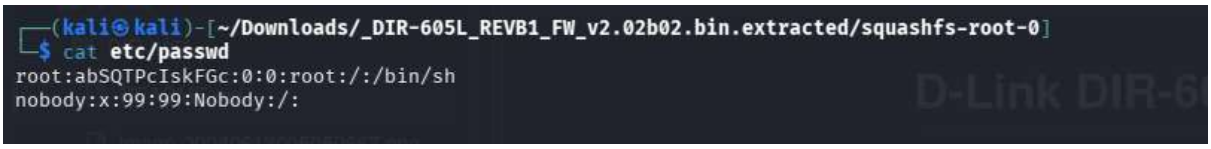
5. Exploration du filesystem extrait

```
cd _firmware.bin.extracted/
ls
find . -type f -exec file {} \; | grep ELF
```

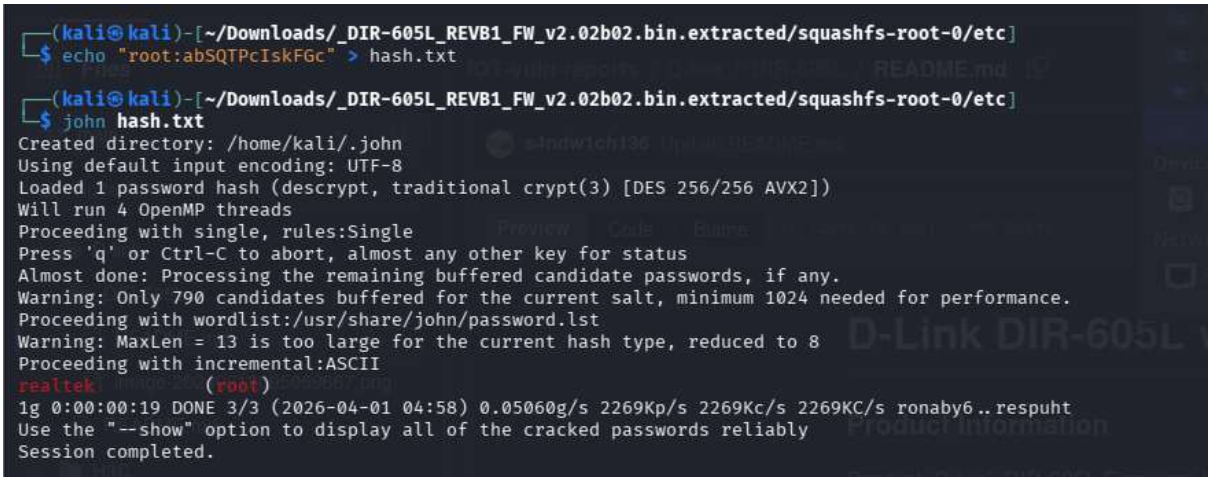
Plusieurs fichiers ELF sont trouvés.

6. Analyse des fichiers critiques

- /etc/passwd, /etc/shadow



Le hash du mot de passe en clair a été trouvé notamment celui de root.



En utilisant, l'outil john pour trouver le mot de passe qui est realtek.

Recherche de fichiers dans squashfs-root-0, on trouve un dossier web.

Découverte d'un fichier shell.asp qui est un web shell. Ils permettent d'exécuter des commandes sur un serveur distant.

```
<html>
<! Copyright (c) Realtek Semiconductor Corp., 2003. All Rights Reserved. →
<head>
<meta http-equiv="Content-Type" content="text/html">
<META http-equiv=Pragma content=no-cache>
<title>System Command</title>
<script>
function saveClick(){
        field = document.formSysCmd.sysCmd ;
        if(field.value.indexOf("ping")==0 && field.value.indexOf("-c") < 0){
                alert('please add "-c num" to ping command');
                return false;
        }
        if(field.value == ""){
                alert("Command can't be empty");
                field.value = field.defaultValue;
                field.focus();
                return false ;
        }
        return true;
}
```

```
        return true;
}
</script>
</head>

<body>
<blockquote>
<h2><font color="#0000FF">System Command</font></h2>


<form action=/goform/formSysCmd method=POST name="formSysCmd" id="formSysCmd">
<table border=0 width="500" cellspacing=0 cellpadding=0>
  <tr><font size=2>
 This page can be used to run target system command.
  </tr>
  <tr><hr size=1 noshade align=top></tr>
  <tr>
        <td>System Command: </td>
        <td><input type="text" name="sysCmd" value="" size="20" maxlength="50"></td>
        <td> <input type="submit" value="Apply" name="apply" onClick='return saveClick()'></td>

  </tr>
</table>
  <input type="hidden" value="/shell.asp" name="submit-url">
</form>
  <textarea rows="15" name="msg" cols="80" wrap="virtual"><% sysCmdLog(); %></textarea>

  <p>
  <input type="button" value="Refresh" name="refresh" onClick="javascript: window.location.reload()">
  <input type="button" value="Close" name="close" onClick="javascript: window.close()"></p>
</blockquote>
</font>
</body>

</html>
```

Le serveur ne valide pas ce qu'il reçoit. Les modifications sont faciles puisqu'elles ne sont pas validées.

Le paramètre sysCmd est passé directement dans le shell du système sans filtrage. Il est donc possible d'exécuter des commandes à distances.

Un utilisateur peut d'envoyer des commandes arbitraires au système d'exploitation via le point d'entrée /goform/formSysCmd.

Risque : risque de vol de données, de modification de configuration de la part d'un attaquant.

CVE-2018-20057 Detail

Description

An issue was discovered in /bin/boa on D-Link DIR-619L Rev.B 2.06B1 and DIR-605L Rev.B 2.12B1 devices. goform/formSysCmd allows remote authenticated users to execute arbitrary OS commands via the sysCmd POST parameter.

Metrics

CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD **Base Score:** 8.8 HIGH **Vector:** CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Weakness Enumeration

CWE-ID	CWE Name	Source
CWE-78	Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')	NIST